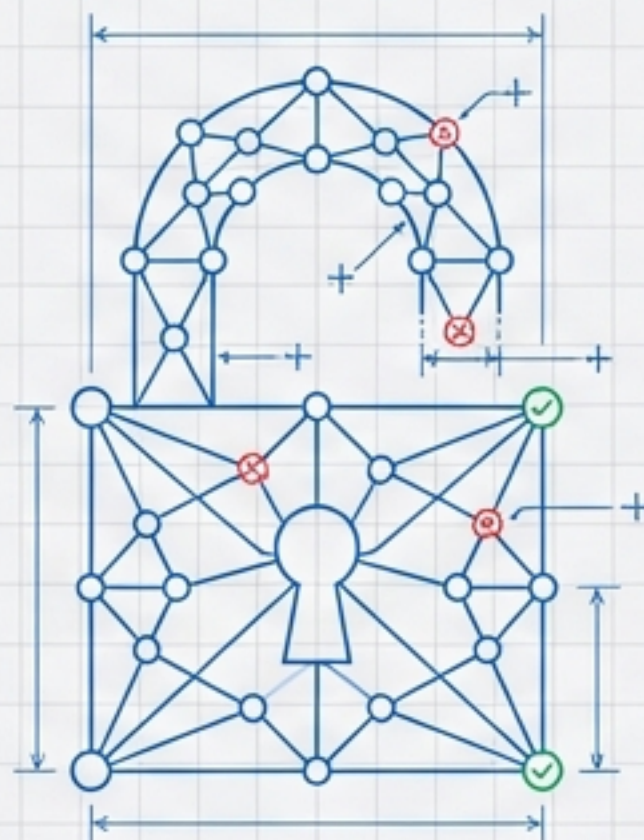


The Architecture of Prevention

Evidence from 10 interventions in 9 days at SGraph Send.



08 FEB 2026

EXPERIMENT DURATION

16 FEB 2026

09 FEB

10 FEB

11 FEB

12 FEB

13 FEB

14 FEB

15 FEB

16 FEB

17 FEB

18 FEB

19 FEB

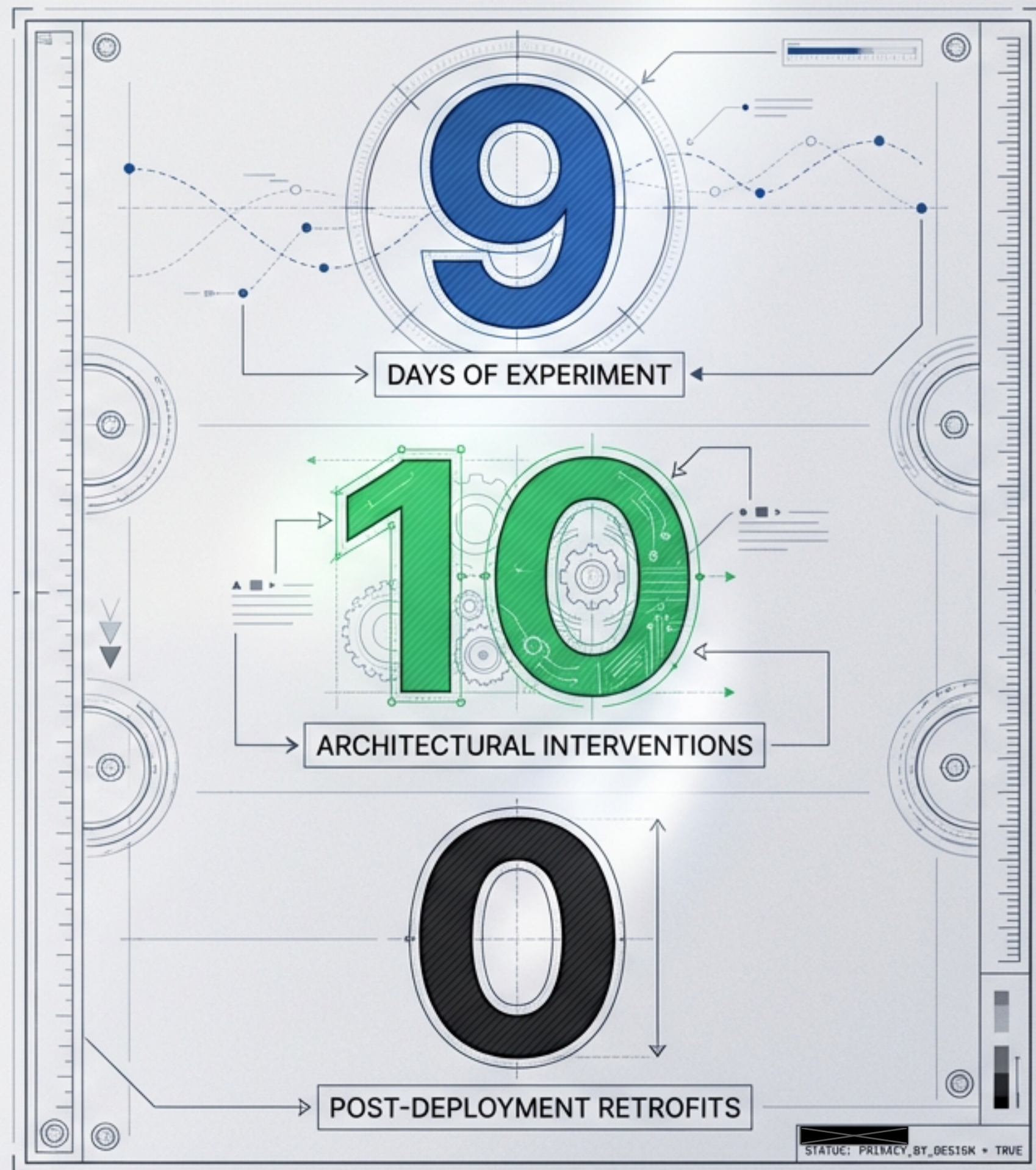
The Cheapest Privacy Fix is the One You Never Make

SGraph Send is a zero-knowledge service built by AI agents.

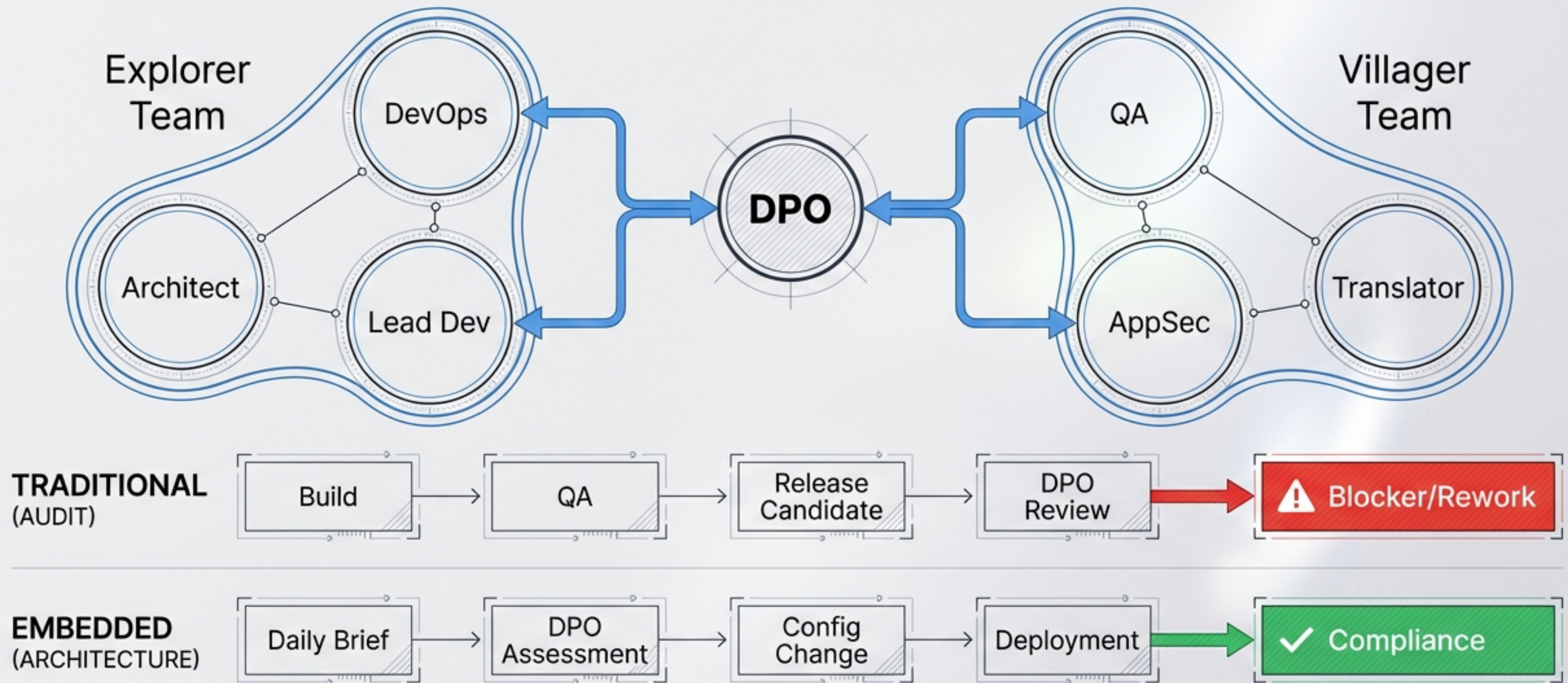
From 8–16 February 2026, we embedded a Data Protection Officer (DPO) not as a reviewer, but as a builder.

The Insight: The value of the DPO is not in what they find. It is in when they find it.

Retrofitting privacy means admitting the system was non-compliant. Designing privacy in means the system was never non-compliant.



A Seat at the Table: The 17+1 Team Model



Intervention 1: The CloudFront 'Smoking Gun'

15 Feb 2026: Preventing Illegal Processing Before it Started

Code Diff

THE DEFAULT CONFIG (GHOST PATH)

```
CloudFront-Real-Time-Log-Config {  
  fields: [  
    'date',  
    'time',  
    'c-ip', // CLIENT IP INCLUDED  
    'x-forwarded-for', // PROXY IP INCLUDED  
    'c-country'  
  ]  
}
```

Result: Illegal PII storage in S3 from Minute 1.

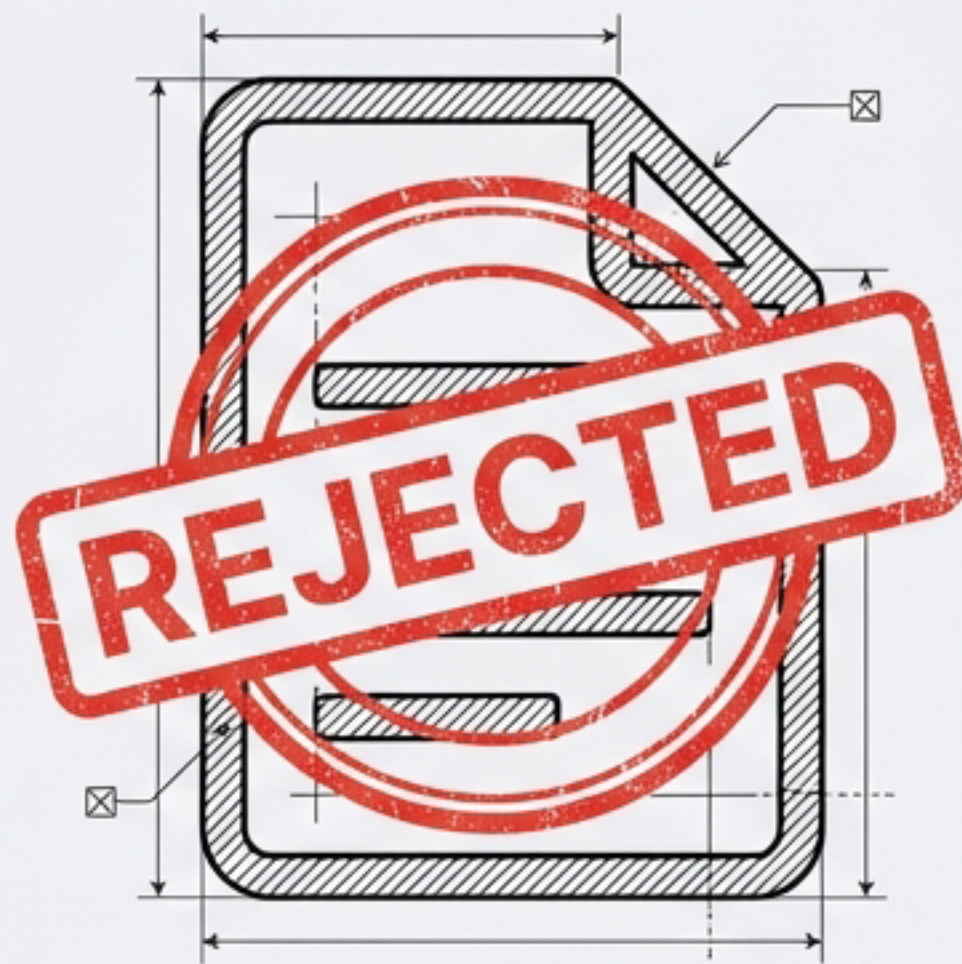
THE DPO INTERVENTION

```
CloudFront-Real-Time-Log-Config {  
  fields: [  
    'date',  
    'time',  
    // 'c-ip' EXCLUDED  
    // 'x-forwarded-for' EXCLUDED  
    // 'c-country' EXCLUDED  
  ]  
}
```

Result: 0 Bytes of PII stored. No retrofit needed.

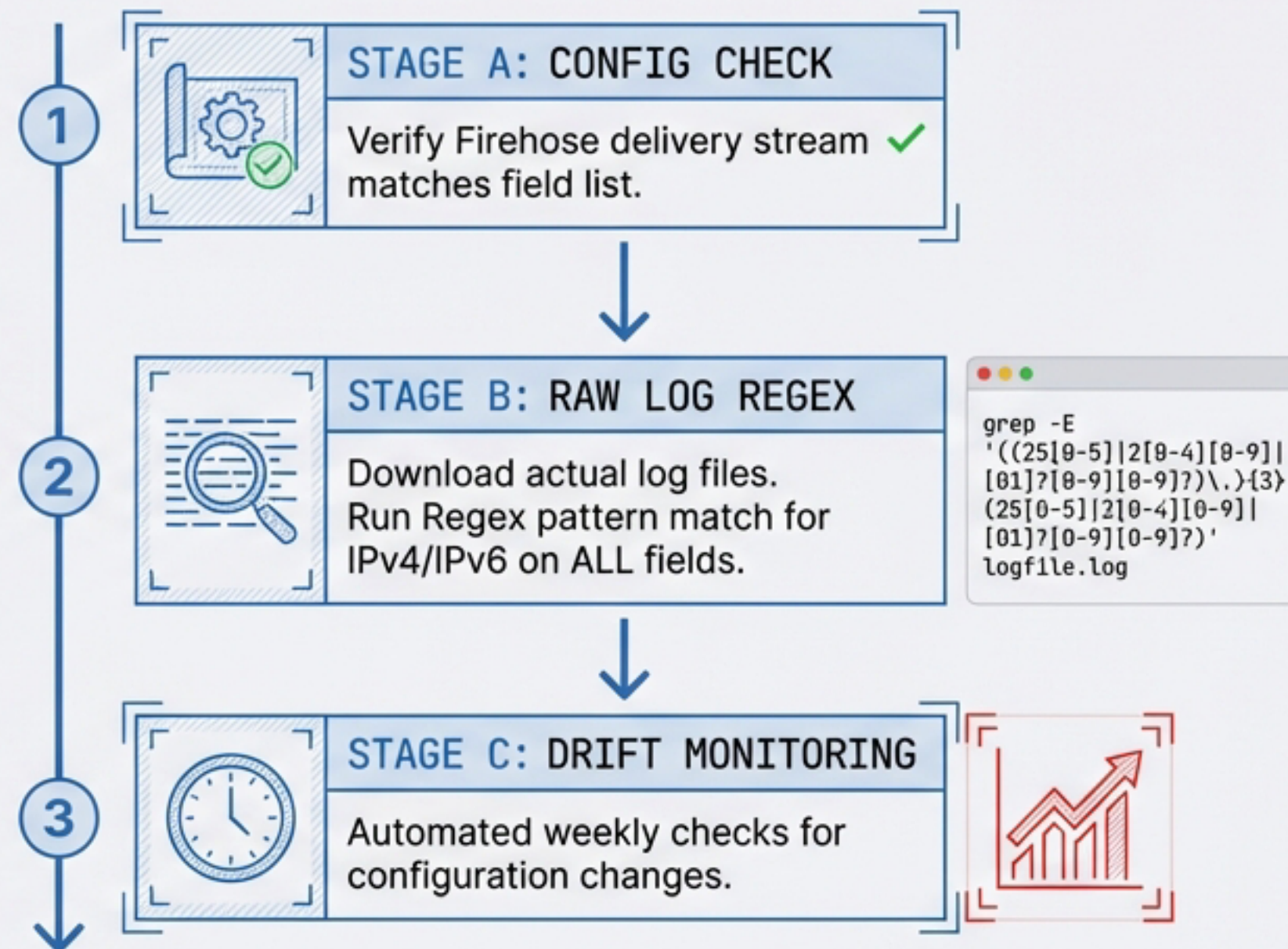
Savings: 2-4 Engineering Sessions + Breach Assessment Avoided.

Intervention 2: Trust but Verify (Empirically)



Documentation is not Evidence.

The DPO rejected screenshots of the configuration settings. GDPR Art 5(2) requires proof.



**“A configuration screenshot is a statement of intent.
A regex scan of a raw log file is a statement of fact.”**

Intervention 3: Trust is the Architecture

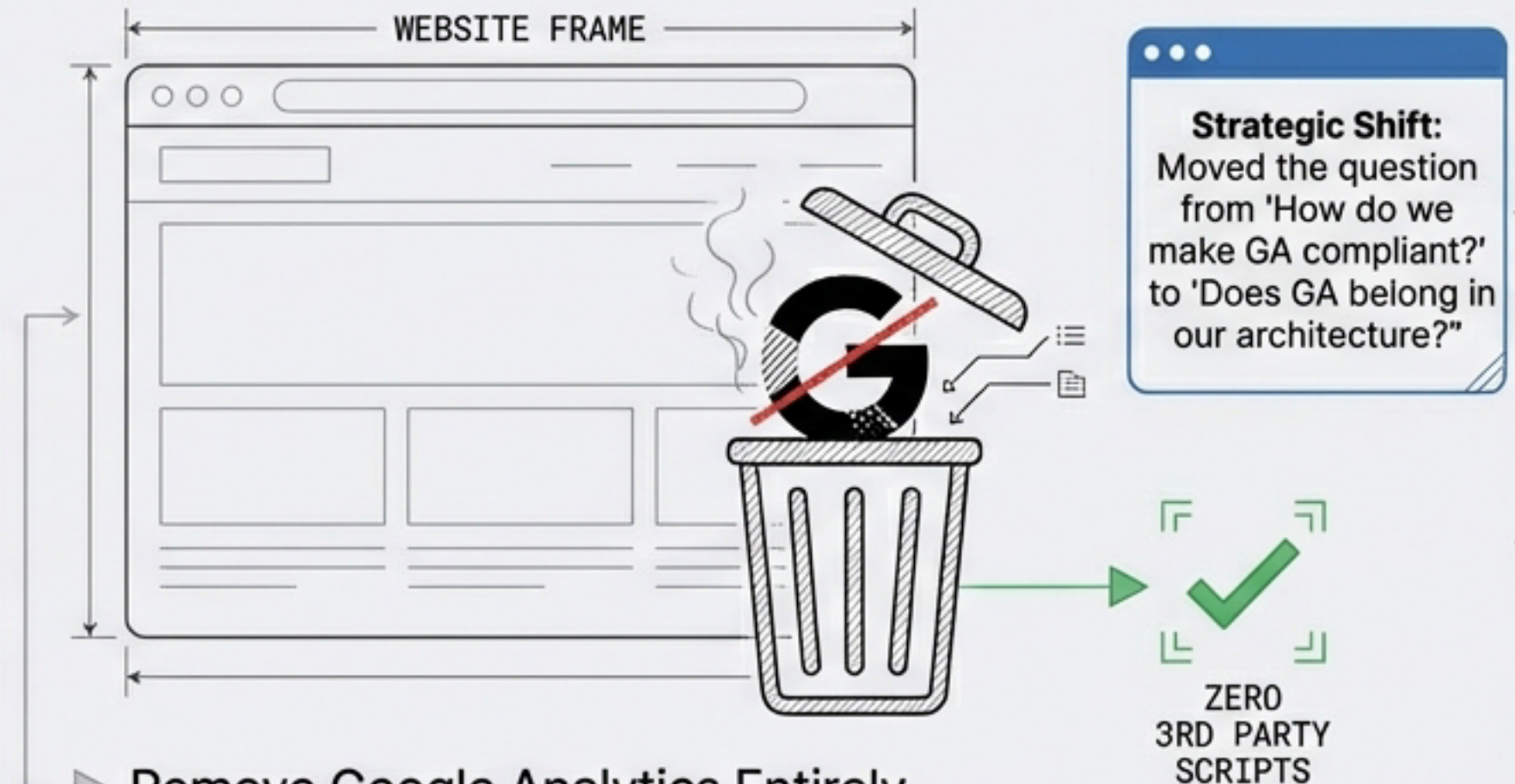
The Removal of Google Analytics (13 Feb)

MITIGATION (The Industry Standard)



Keep Google Analytics + Add Consent Banner.
Result: Complex, fragile, supply chain risk.

ARCHITECTURE (The SGraph Way)



Remove Google Analytics Entirely.
Result: Zero cookies. Zero 3rd party scripts.

Intervention 4: Catching the Silent Regressions

New features often unknowingly break old privacy promises.

PROPOSED MANIFEST (15 Feb)

```
{
  'transfer_id': 'tx_99281',
  'file_name': 'Quarterly-Medical-Report-Smith.pdf',
  // PLAIN TEXT LEAK
  'size': '4MB'
}
```

DATA LEAK: Filenames contain Personal Data.

CORRECTED MANIFEST

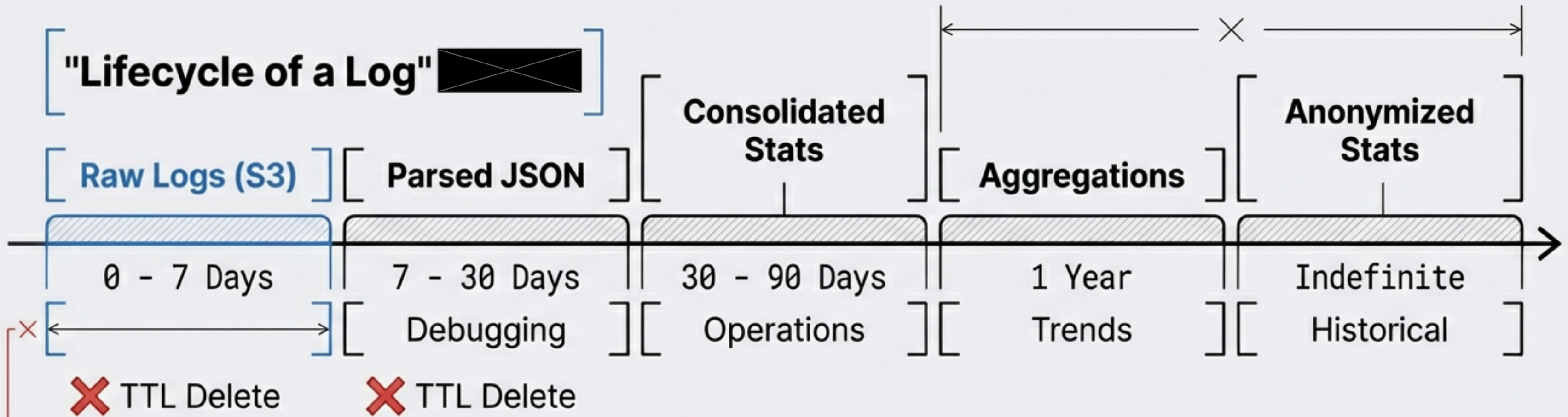
```
{
  'transfer_id': 'tx_99281',
  'file_name': null, // REMOVED OR ENCRYPTED
  'size': '4MB'
}
```

The Lesson:

A feature can be compliant on Tuesday and broken on Wednesday by a developer unaware of the privacy context.

Intervention 6: Cost is Not a Lawful Basis

Lifecycle of a Log in Inter



ENGINEERING HABIT: "Store everything in Glacier forever because it's cheap."
LEGAL REALITY: GDPR Art 5(1)(e) - Cost is not a lawful basis for retention.

Intervention 5: The Feature Pivot

When a 'Feature' Becomes a Legal Role Change

Proposal: Optional Unencrypted Mode

ENCRYPTED (Current)

- ✓ **Status:** Software Provider
- 🔒 **Data:** Ciphertext (Unreadable)
- ✓ **Breach:** No ICO Notification
- ✓ **DPIA:** Not Required

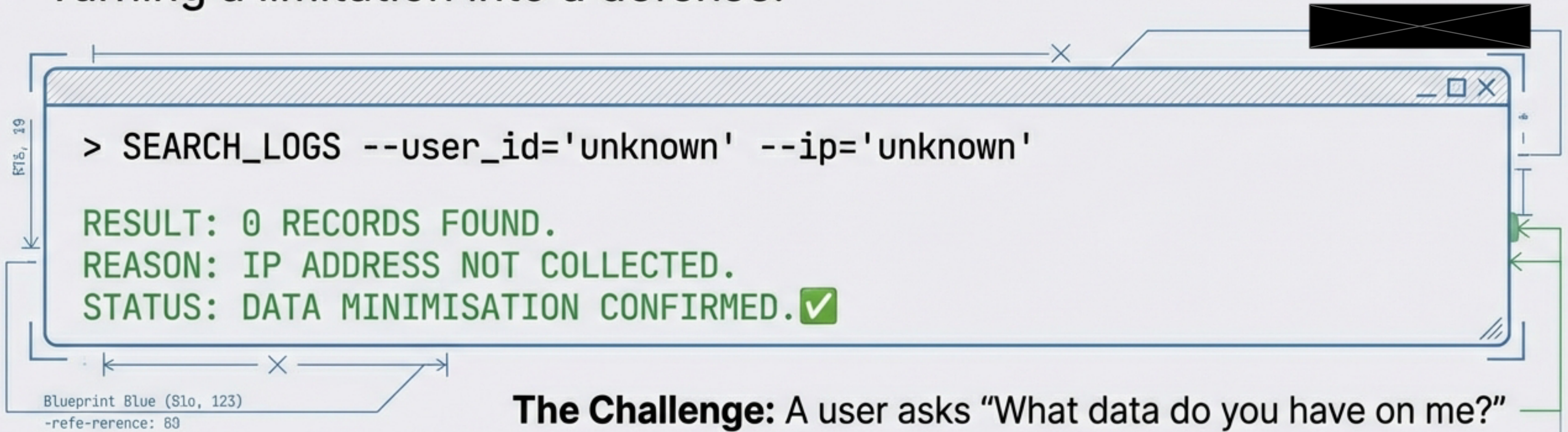
UNENCRYPTED (Proposed)

- ⚠️ **Status:** DATA PROCESSOR (High Risk)
- 🔓 **Data:** Plaintext (Readable)
- 🚨 **Breach:** Mandatory Notification
- ⚠️ **DPIA:** MANDATORY (Art 35)

The DPO Analysis: Allowing unencrypted files changes SGraph from a tool provider to a Data Processor. This required a full DPIA, new Terms, and strict retention silos.

The DSAR Advantage

Turning a limitation into a defense.



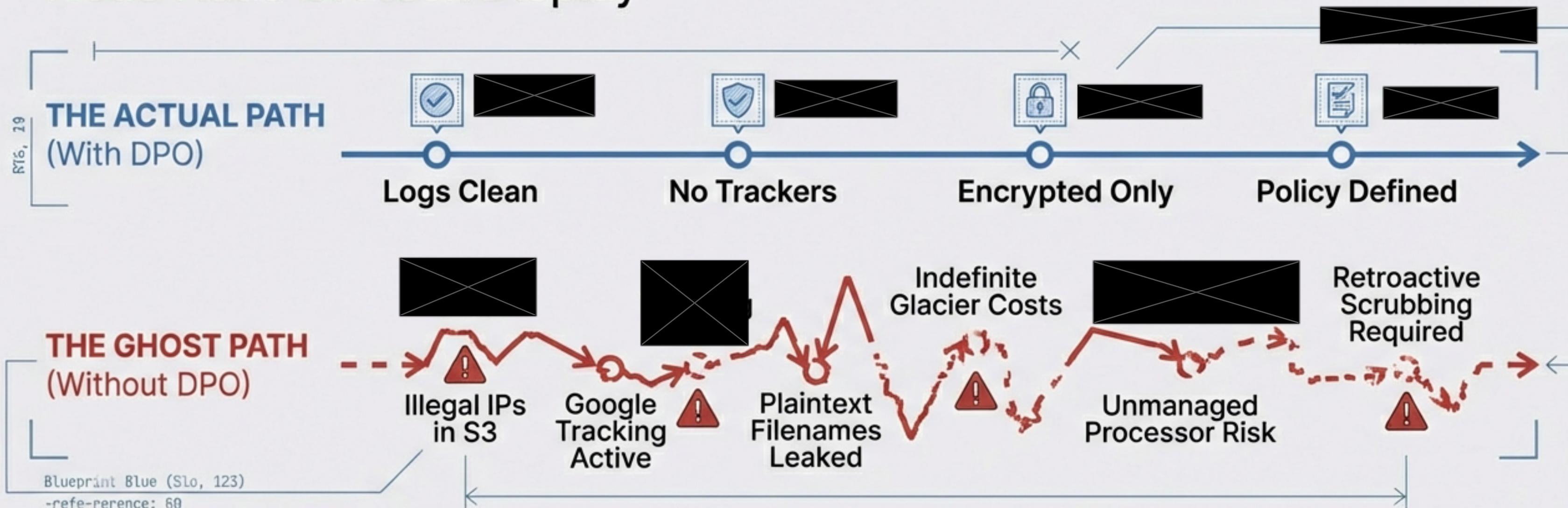
The Challenge: A user asks “What data do you have on me?”

The Answer: “We can’t tell you. By design.”

Because of Intervention 1 (No IPs), we cannot link a request to a person.
The inability to fulfill a DSAR becomes proof of data minimisation excellence.

The Counterfactual: SGraph Without a DPO

Neue Haas Grotesk Display



Result: The system would work technically. But it would be legally toxic.

STATUS: EMPIRICAL_VERIFICATION_PROTOCOL -
- STATUS: ARCHITECTURAL_TRUST_PROTOCOL - TRUE

Evidence Summary Matrix

INTERVENTION	CONFIDENCE	GDPR ART	OUTCOME
CloudFront IP Exclusion	HIGH	Art 25	Prevented PII in logs ✓
Empirical Verification	HIGH	Art 5(2)	Prevented false assurance ✓
GA Removal	HIGH	PECR	Prevented 3rd party tracking ✓
File Name Regression	HIGH	Art 5(1)c	Prevented data leak ✓
Unencrypted Mode DPIA	HIGH	Art 35	Prevented undefined Processor role ✓
Log Retention Tiering	MED-HIGH	Art 5(1)e	Prevented indefinite storage ✓
LaunchList DPA	MED	Art 28	Identified processor relationship ✓

Blueprint Blue (Slo, 123)

-reference: 60

STATUS: EMPIRICAL_VERIFICATION_PROTOCOL - ✓
- STATUS: ARCHITECTURAL_TRUST_PROTOCOL - TRUE

Honest Reporting: The Open Risks

An embedded DPO makes risks visible, not invisible.

OPEN RISKS (As of 16 Feb)



P1

MISSING PRIVACY POLICY

Project is live. Art 13 requirement unmet.



P2

IP HASHING LAWFUL BASIS

Salted hashes are pseudonymised data. LIA not documented.



P2

LAUNCHLIST DPA

Vendor processing data without signed Art 28 agreement.

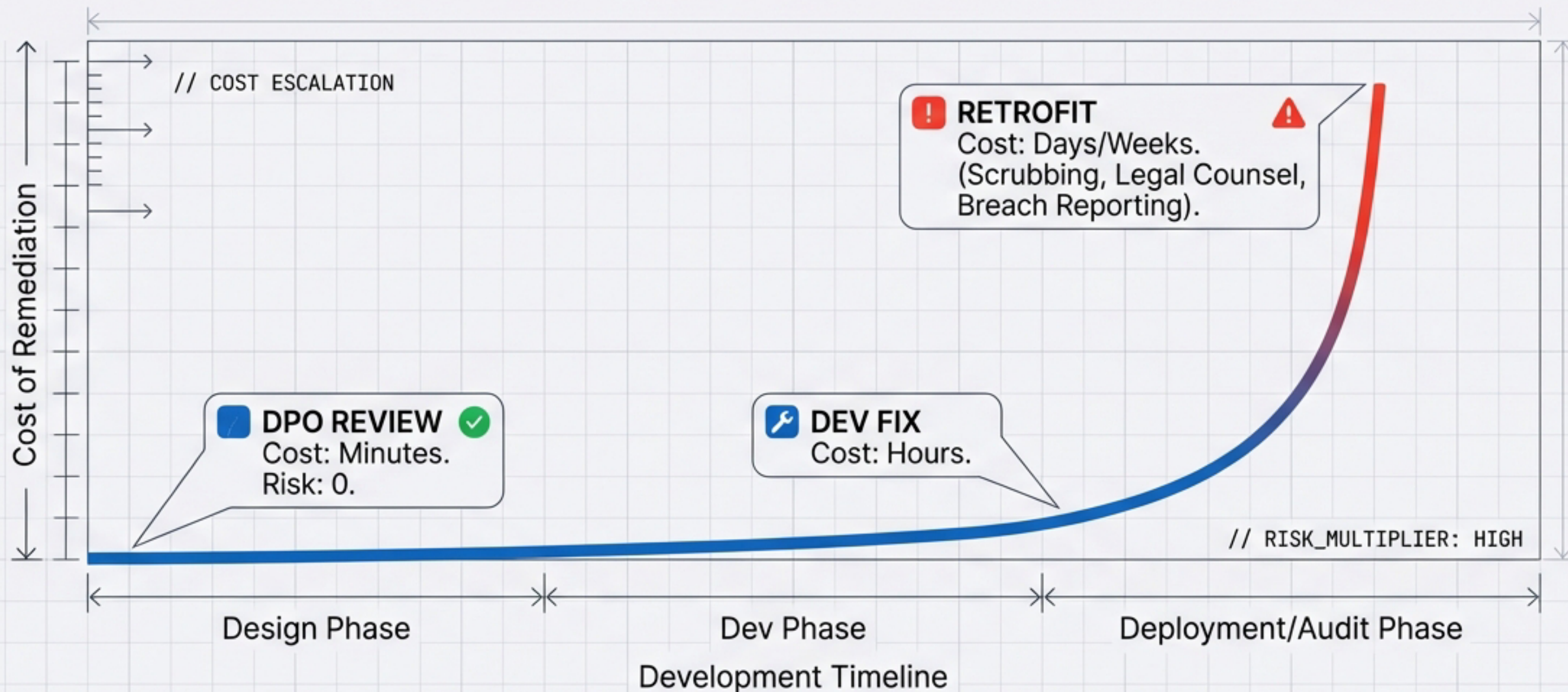


P3

DATA MAP VELOCITY

Documentation lagging behind new data flows (CloudTrail, S3).

The ROI of 'Left-Shifted' Privacy



“Designing it in is an asset. Retrofitting it is an admission of failure.”

Architecture Over Audit



When the DPO reviews at the end, the output is a list of problems to fix.

When the DPO is embedded from the start, the output is an architecture that does not have those problems.

**Stop treating the DPO as a gatekeeper.
Give them a shovel and let them build.**